BC3 – Chapitre 21 : tout ce qu'il faut savoir

Cybersécurité et environnement numérique sécurisé – fiche complète (à jour au 4 novembre 2026)

Mode d'emploi

Cette fiche résume tout le chapitre 21. Elle traite d'abord des acteurs et des référentiels de la cybersécurité (ANSSI, cybermalveillance.gouv.fr, CERT Santé, PGSSI-S, CaRE, identité numérique des professionnels). Elle traite ensuite de l'environnement de travail sécurisé (mots de passe, double authentification, mises à jour, comptes, messagerie, chiffrement, antivirus, sauvegardes), des actions malveillantes (hameçonnage, rançongiciel, fraude au virement, ingénierie sociale, prestataires), de la réaction à un incident et de la sensibilisation. Viennent enfin l'exemple d'Inès, les approfondissements (objets connectés, travail à distance, petites structures), la L3, les vingt cas guidés et le jury. Elle suit l'ordre du cours (21.3 à 21.8).

Compétences : **C3.6** (cœur : « maintenir son environnement numérique de travail sécurisé » ; activité 3.6 « application des règles de cybersécurité en santé »), C3.5 (messagerie, connexion aux plateformes, identité numérique), C3.1 (continuité d'un projet malgré un incident). Référentiel : **arrêté du 27/11/2024** (JO du 17/12/2024). Le guide 2025 rattache au BC3 la cybersécurité du **référentiel socle du numérique en santé** (environ **10 h** sur les deux ans). CNED : Essentiels 2e année, module 1, **S7 « Santé et numérique » p. 25-27**, et module Hygiène M1 **S4 § 5** (étiquettes scannées, conservation 6 mois).

Corrections du fascicule CNED à appliquer :

- **Stratégie « e-santé 2020 »** : remplacée par « Ma santé 2022 » (2019), puis par la **feuille de route du numérique en santé 2023-2027** (mai 2023), renforcée pour la cybersécurité par le **programme CaRE** (décembre 2023).
- **DMP « à créer »** : depuis **2022**, il fait partie de **Mon espace santé**, ouvert pour chaque assuré sauf opposition.
- **Accès par carte CPS + lecteur** : il existe aussi l'**e-CPS** (sur téléphone) et **Pro Santé Connect**.
- **« Hautement sécurisé »** : aucun service n'est sûr à lui seul. La sécurité dépend aussi des **pratiques** : mots de passe, double authentification, poste verrouillé, vigilance.
- Le CNED **ne traite pas** la cybersécurité en détail (il l'évoque seulement).

Autres précisions :

- **NIS 2** (directive (UE) 2022/2555) : la loi française de transposition (projet de loi « résilience ») n'était **pas définitivement adoptée** au 26/10/2026. J'ai vérifié en ligne : elle était encore en discussion au Parlement à l'automne 2026. **Vérifier sur Légifrance** avant de citer ses obligations.
- **Exercice 21.79** (portable volé la veille, découvert non chiffré le mercredi) : le cours fait partir les 72 h du mercredi. Par **prudence**, on peut les faire partir de la connaissance du **vol** (la veille), comme le cours le fait lui-même dans l'exemple du week-end.
- Les autres faits ont été vérifiés : ANSSI (décret 2009-834 du 7/7/2009), guide d'hygiène (42 mesures, 2017), CNIL mots de passe (délibération 2022-100 du 21/7/2022), loi **LOPMI 2023-22** (article L12-10-1 du code des assurances), article **323-1** (3 ans, 100 000 €), 17Cyber (17/12/2024), CaRE (décembre 2023). Les calculs du cours sont justes. Les exemples chiffrés sont **fictifs**.

1. Acteurs, vocabulaire, identité numérique (21.3.1)

Cybersécurité : mesures **techniques, organisationnelles et humaines** qui protègent les systèmes d'information et les données. **Trois objectifs (DIC)** :

- **Disponibilité** : pouvoir accéder aux informations et aux outils quand on en a besoin ;
- **Intégrité** : l'information est exacte et n'a pas été modifiée sans autorisation ;
- **Confidentialité** : seules les personnes autorisées y ont accès.

On ajoute la **traçabilité** (qui a fait quoi, quand) et l'**authentification**. Exemple 21.2 : bilan au mauvais médecin = confidentialité ; texture changée sans raison = intégrité (risque de fausse route) ; messagerie en panne = disponibilité ; identifiant partagé = traçabilité.

Système d'information : personnes, procédures, outils **et** données (la liste papier des régimes en fait partie).

Vocabulaire : **bien à protéger** (liste des régimes) · **menace** (attaquant, erreur, panne) · **vulnérabilité** (poste non mis à jour) · **risque** (vraisemblance × gravité) · **incident** (atteinte réelle) · **violation de données** (destruction, perte,

modification, divulgation ou accès non autorisé à des données personnelles, RGPD article 4).

Acteurs :

- **ANSSI** : autorité nationale ; guides (hygiène informatique), recommandations ;
- **cybermalveillance.gouv.fr** : assistance aux victimes, prévention, observation ; fiches, diagnostic, prestataires de proximité ;
- **17Cyber** (ouvert le **17/12/2024**) : assistance et mise en relation avec un policier ou un gendarme ;
- **CERT Santé** : opéré par l'**ANS** ; appui aux structures de santé ; reçoit les signalements d'incidents ;
- **CNIL** : violations de données (chapitre 20) ; **police, gendarmerie** : plainte.

Chronologie : **7/7/2009** ANSSI (décret 2009-834) → **2017** guide d'hygiène informatique (**42 mesures**) et cybermalveillance.gouv.fr → **25/5/2018** RGPD (article **32** sécurité, **33** notification) → **14/12/2022** NIS 2 (transposition attendue avant le 17/10/2024) → **décembre 2023** CaRE → **17/12/2024** 17Cyber.

Identité numérique : **identification** (dire qui l'on est) · **authentification** (le prouver) · **habilitation** (ce qu'on a le droit de faire). Moyens : **CPS** (carte à puce + code), **e-CPS** (sur le téléphone, sans lecteur), **Pro Santé Connect** (une identification forte pour de nombreux services), mot de passe + double authentification. Les diététiciens sont au **RPPS** et peuvent obtenir une CPS ou une e-CPS. **Prêter sa CPS = prêter sa signature** : interdit (exemple 21.3 ; la stagiaire reçoit un compte personnel, limité et daté).

PGSSI-S (politique générale de sécurité des systèmes d'information de santé, ANS) : principes fondateurs, référentiels (identification, authentification, **imputabilité**), guides pratiques. Un référentiel n'est pas une loi : il devient **opposable** seulement quand un texte le prévoit.

Programme CaRE (« Cybersécurité accélération et Résilience des Établissements », **décembre 2023**, environ **750 M€**), après les attaques de **Dax** et **Villefranche-sur-Saône** (février 2021) et du **CH Sud Francilien** (août 2022). **4 axes** : gouvernance et résilience · ressources et mutualisation · sensibilisation · sécurité opérationnelle. Le service diététique participe aux exercices de crise et décrit les informations vitales des repas.

Obligations selon la structure : établissement de santé (RGPD, HDS, signalement des incidents graves, DPO, CERT Santé, ARS) ; médico-social ; cuisine centrale (dès qu'il y a des régimes ou allergies nominatifs) ; association ; **diététicien libéral, responsable du traitement**. Le RGPD (article **32**) exige des **mesures adaptées au risque**, pas une liste d'outils. Exemple 21.6 : en **décembre 2020**, la CNIL a sanctionné deux médecins libéraux dont les images médicales étaient accessibles sur Internet.

Se former : **SecNumacadémie** (ANSSI, 2017, attestation), kit de cybermalveillance.gouv.fr, **Atelier RGPD** de la CNIL (2019), ANS, GRADeS.

Quel texte sanctionne quoi ?

Texte	Ce qu'il protège	Sanction
Code pénal **323-1**	le système contre l'accès ou le maintien frauduleux	**3 ans, 100 000 €**
Code pénal **226-13**	le secret professionnel	**1 an, 15 000 €**
CSP **L. 1110-4**	vie privée et secret du patient	renvoie au code pénal
RGPD **article 83**	les données personnelles	**20 M€ ou 4 %** du CA mondial

Une structure attaquée est **victime** (323-1) **et** peut être sanctionnée par la CNIL si elle n'avait pas pris les mesures attendues.

Lire une adresse (exemple 21.10) : on lit le **nom de domaine**, juste avant le premier « / ». « ameli.fr-remboursement.info » est suspect. Le **cadenas** prouve que la connexion est chiffrée, **pas** que le site est honnête.

2. Mots de passe et double authentification (21.3.2)

Six gestes d'hygiène numérique (figure 21.1) :

1. mots de passe **longs et uniques**, dans un **gestionnaire** ;
2. **double authentification** ;
3. **mises à jour** ;
4. **sauvegardes** testées, dont une hors ligne ;
5. **vigilance** (liens, pièces jointes, demandes inhabituelles) ;
6. usages **séparés**, écran **verrouillé**, aucune clé USB inconnue.

Attaques : **force brute** (toutes les combinaisons) ; **dictionnaire** (mots courants, variantes comme « Soleil2026! »). **Nombre de combinaisons = (caractères possibles) puissance (longueur)**. Avec 10 puissance 10 essais par seconde :

Mot de passe	Combinaisons	Temps
8 chiffres	10 puissance 8	0,01 s
8 minuscules	≈ 2,1 × 10 puissance 11	≈ 21 s
10 minuscules	≈ 1,41 × 10 puissance 14	≈ 3 h 55
11 minuscules	≈ 3,67 × 10 puissance 15	≈ 4,2 jours (× 26)
12 minuscules	≈ 9,54 × 10 puissance 16	≈ 110 jours
4 mots (liste de 7 776)	≈ 3,66 × 10 puissance 15	≈ 4,2 jours
6 mots	≈ 2,21 × 10 puissance 23	≈ 700 000 ans
12 caractères (62 possibles)	≈ 3,2 × 10 puissance 21	> 10 000 ans

Allonger vaut mieux que compliquer. CNIL, délibération 2022-100 du 21/7/2022 : mot de passe suffisant seul = **12 caractères** de 4 types, ou **14 caractères** de 3 types, ou **phrase de passe d'au moins 7 mots** ; exigences plus faibles si le service bloque les essais ou ajoute un second facteur.

Double authentification : **ce que je sais** (mot de passe), **ce que je possède** (CPS, téléphone, clé), **ce que je suis** (empreinte). Mot de passe + question secrète **n'est pas** une double authentification (même catégorie). **Fatigue des notifications** : je ne valide **jamais** une connexion que je n'ai pas lancée ; si je reçois des demandes, mon mot de passe est connu : je le change et je préviens (exemple 21.12).

Gestionnaire de mots de passe : coffre **chiffré**, un seul **mot de passe maître** protégé par double authentification ; il ne remplit rien sur une fausse page ; partage contrôlé. Coût exemple : 3 € × 14 × 12 = **504 €/an** = 36 €/personne. « Tous les œufs dans le même panier » ? Ils y sont déjà si l'on réutilise un mot de passe.

3. Mises à jour, comptes, messagerie, chiffrement (21.3.2)

Mises à jour : elles corrigent des **failles**. **Fin de support** : plus aucune mise à jour de sécurité. Appareils oubliés : poste des sondes de température (l'isoler), box et imprimante (mot de passe par défaut), vieux téléphone, extensions. **Méthode en 5 étapes** : inventaire, mises à jour automatiques, créneau fixe, contrôle mensuel, remplacement budgété. Priorité (exemple 21.29) : **système d'exploitation** (faille exploitée) > navigateur > logiciel métier (après test) > pilote.

Moindre privilège : chacun n'a que les accès nécessaires, le temps de sa mission. Arrivée (compte nominatif validé) · changement de poste · **départ (désactiver le dernier jour)** · **revue annuelle** (exemple : 11/64 = **17,2 %** de comptes à fermer). Le **compte administrateur** ne sert qu'aux interventions techniques. **« Un compte = une personne ; il naît à l'arrivée et meurt au départ. »**

Messagerie : professionnelle ; **MSSanté** pour les données de santé ; vérifier le destinataire (une erreur d'envoi = une violation) ; **copie cachée (Cci)** pour les envois groupés ; lien de partage **nominatif avec expiration** ; pas de transfert automatique vers une adresse personnelle. Exemple 21.18 : 140 adresses visibles = 140 × 139 = **19 460** affichages, et le titre « Cuisine et diabète » révèle une donnée de santé. Archive chiffrée : mot de passe envoyé **par un autre canal**. Message d'absence : ni lieu de vacances, ni numéro personnel, ni mot de passe partagé.

Chiffrement : rend les données illisibles sans la clé ; gratuit sur les systèmes récents. Il **réduit la gravité** d'un vol : si les données sont inintelligibles, l'information des personnes n'est pas exigée (RGPD **article 34**) ; la violation est quand même inscrite au registre.

Antivirus, pare-feu, filtrage, blocage des macros (ne jamais « activer le contenu »), analyse des supports. Logiciels malveillants : virus, ver, cheval de Troie, logiciel espion, rançongiciel. **L'antivirus ne suffit pas** ; une alerte « mise en quarantaine » se signale quand même (exemple 21.21).

Plateformes : taper l'adresse ou utiliser un favori, vérifier la barre d'adresse, **se déconnecter**, ne pas enregistrer de mot de passe sur un poste partagé, double authentification, adresse professionnelle, identités pro et perso séparées.

4. Les sauvegardes (21.3.2)

Règle 3-2-1 : **3** copies, sur **2** supports différents, dont **1** hors site ou hors ligne ; **restauration testée**.

Type	Ce qui est copié	Pour restaurer
Complète	tout	la dernière complète
Incrémentale	ce qui a changé depuis **la dernière sauvegarde**	la complète + **toutes** les incrémentales, dans l'ordre
Différentielle	ce qui a changé depuis **la dernière complète**	la complète + la dernière différentielle

Exemple (40 Go + 1,5 Go/jour) : incrémentale **49 Go/semaine** ; différentielle 71,5 Go/semaine. Si l'incrémentale du mardi est illisible, on ne restaure de façon fiable que jusqu'au lundi soir.

Perte de données maximale admissible (RPO) : ce qu'on accepte de perdre, en temps. **Durée maximale d'interruption admissible (RTO)** : combien de temps l'activité peut s'arrêter. On les fixe **avec les métiers** (la diététicienne sait ce qui est vital pour la cuisine). Exemples : sauvegarde hebdomadaire = 160 fiches perdues contre 40 en quotidienne (**− 75 %**) ; 35 modifications de régime par jour : une nuit perdue = 35, toutes les 2 h ≈ 6 ; exercice 21.28 : sauvegarde de nuit = **11 h 50** perdues, toutes les 2 h = **1 h 50**.

Test de restauration en 5 étapes : fichier réel, restaurer à part, vérifier et dater, **chronométrer** (comparer au RTO), consigner (chaque trimestre). **Protéger les sauvegardes** : copie déconnectée ou non modifiable, hors site, chiffrée, comptes séparés, **conservation suffisante** (une intrusion peut rester cachée des semaines ; « 7 jours sur la même infrastructure » ne suffit pas → 30 jours, infrastructure distincte). Exercice 21.27 : 49 × 5 semaines × 2 copies = **490 Go**.

5. Les actions malveillantes (21.3.3)

Quatre grandes menaces (figure 21.3) : **hameçonnage** (faux message pour faire cliquer ou voler des identifiants) · **rançongiciel** (chiffre les données, exige une rançon) · **usurpation d'identité** (faux dirigeant, faux fournisseur) · **ingénierie sociale** (urgence, autorité, sympathie, peur, familiarité). S'y ajoute le **faux support technique**. La santé est une **cible** (CHSF 2022).

Une attaque par rançongiciel en 6 étapes : **entrée** (mot de passe volé, faille, accès à distance) → **installation** → **exploration** (serveurs, sauvegardes) → **vol** de données → **chiffrement** (souvent la nuit ou le week-end) → **chantage**. **Double extorsion** : chiffrer **et** menacer de publier ; même avec de bonnes sauvegardes, il y a violation de confidentialité. Exemple 21.30 : attaquant entré 23 jours avant, sauvegardes de 15 jours insuffisantes.

Nouvelles formes d'hameçonnage : SMS (« colis bloqué, 1,99 € » → transférer au **33700**), appel vocal, **code QR** collé sur une affiche, hameçonnage **ciblé**, boîte d'un collègue piratée. Avec l'IA, les messages n'ont plus de fautes : **le vrai indice est la demande inhabituelle** (identifiants, paiement, urgence). Une **voix** peut être imitée (exemple 21.42, 8 400 €).

Fraude au virement (faux fournisseur, faux dirigeant, fausse facture, messagerie du fournisseur piratée). **Trois vérifications** : ne pas se fier au **seul message** ; **rappeler au numéro connu** ; **double validation** au-dessus d'un seuil, sans exception. La vraie adresse du fournisseur ne prouve rien.

Ingénierie sociale à l'accueil : « Je ne donne pas d'information par téléphone ; je vérifie et je rappelle au numéro officiel. » Le faux technicien cherche des informations « anodines » pour préparer une attaque.

Arnaques visant les patients : cure miracle (« remplace la metformine »), produit minceur (essai à 1 €), faux remboursement Ameli/CAF, faux matériel médical, faux professionnel. **Aider sans culpabiliser** : écouter, évaluer le danger pour la santé, limiter les dégâts (banque, **rétractation 14 jours**, article L221-18 du code de la consommation), orienter (17Cyber, cybermalveillance.gouv.fr, plainte), prévenir.

Menaces non malveillantes : erreur d'envoi, fausse manipulation, perte, panne, panne du prestataire, sinistre, coupure. **Même réponse** : sauvegardes testées, mode dégradé, droits limités, procédures.

Attaque par un prestataire (chaîne d'approvisionnement) : la structure reste **responsable du traitement** (article 28) et notifie elle-même. Exemple 21.36 : compte « admin / Assoc2024 » commun à tous les clients → compte nominatif, mot de passe unique par client, double authentification, accès ouvert seulement pendant l'intervention, contrat.

Loi : 323-1 (3 ans, 100 000 €), 323-2 et 323-3 (entrave, données modifiées). **Loi LOPMI 2023-22 du 24/1/2023** (article L12-10-1 du code des assurances, depuis avril 2023) : l'assurance n'indemnise qu'après une **plainte dans les 72 h**. **Deux délais de 72 h** à ne pas confondre : **CNIL** (violation de données) et **plainte** (assurance). Exemple 21.37 : samedi 8 h → mardi 8 h pour les deux.

6. Réagir et sensibiliser (21.3.4)

Six étapes de la réaction (figure 21.4) : **isoler** (débrancher du réseau **sans éteindre**) · **alerter** (responsable, référent, DPO) · **préserver** (ne pas payer, garder les traces) · **signaler** (CNIL 72 h si risque, CERT Santé, cybermalveillance.gouv.fr) · **restaurer** (sauvegardes saines, mots de passe changés) · **tirer les leçons** (plainte, retour d'expérience). Ordre de l'exercice 21.49 : isoler, noter l'heure, alerter, ne pas négocier, retour d'expérience.

Main courante : journal daté des faits, décisions, actions (heure, qui), **sur papier**. Elle fixe le départ des 72 h et sert à la plainte, à l'assurance, à la CNIL et au retour d'expérience.

Déclarations : **CNIL** (violation présentant un risque, 72 h, notification complétée ensuite) · **personnes** (risque élevé) · **registre interne** (toute violation) · **CERT Santé et ARS** (incident grave en établissement) · **police** (72 h pour l'assurance) · **assureur**. **Le week-end et les jours fériés ne suspendent pas le délai** : vendredi 18 h 50 → lundi 18 h 50 ; lundi 9/3/2026 9 h 15 → jeudi 12/3 ; mercredi 30/12/2026 22 h → samedi 2/1/2027 22 h. Exemple 21.45 : l'EHPAD apprend le mercredi 11 h la fuite chez l'éditeur (92 résidents) → CNIL avant **samedi 11 h** et information des résidents.

PCA (plan de continuité : maintenir l'activité en **mode dégradé**) ≠ **PRA** (plan de reprise : rétablir les outils). Informations vitales : régimes, textures, allergies, tournées, rendez-vous, patients prioritaires. **La liste de secours est aussi un risque** : réduite, sous clé, datée, ancienne détruite.

Communiquer : équipes, patients, partenaires, médias ; **un seul porte-parole** ; faits vérifiés ; ce que chacun doit faire ; un contact ; « nous ne vous demanderons jamais vos coordonnées bancaires par message ».

Ne pas payer : aucune garantie, la copie reste chez les attaquants, cela finance le crime, la structure devient une cible. **Retour d'expérience en 5 étapes**, **sans coupable** (sanctionner celui qui a cliqué décourage les signalements).

Sensibiliser : séance de 30 min (accroche, jeu « vrai ou suspect ? », six gestes, conduite à tenir, évaluation). **Plan annuel en 6 étapes** : constat, objectifs chiffrés, publics, actions, calendrier (au moins une par trimestre), évaluation. **Exercice d'hameçonnage simulé** : décision de la direction, avis du DPO, information des représentants et de l'équipe (sans la date), message **non cruel** (pas de fausse prime), **aucun mot de passe enregistré**, page pédagogique, résultats **anonymes sans sanction**.

Mesurer avec prudence : IC à 95 % = $p \pm 1{,}96 \times \sqrt{p(1-p)/n}$, si $n \geq 30$, $n \times p \geq 5$ et $n \times (1-p) \geq 5$. Exemple 60 agents : clics 19 (31,7 % [19,9 ; 43,4]) → 7 (11,7 % [3,5 ; 19,8]) ; signalements 10 % → 35 % : tendance encourageante. Exemple 21.53 : 15/60 = 25 % [14,0 ; 36,0] chevauche : pas de conclusion. Exemple 21.56 (75 agents) : clics 24,0 → 14,7 → 8,0 % ; signalements 6,7 → 25,3 → 45,3 %.

Adapter aux métiers : accueil (appels), cuisine (faux fournisseurs, pictogrammes), soignants (destinataire), direction (double validation), domicile (téléphone, feuilles de tournée). **Trois signes d'arnaque** pour les usagers : **l'urgence**, **la demande d'argent ou de données**, **la promesse trop belle**.

7. Inès aux Tilleuls (21.3.5)

Session personnelle sur l'ordinateur de l'accueil, supprimée à la fin du stage, **verrouillage** à chaque absence ; fichiers du projet dans l'**espace partagé sauvegardé** (pas sur sa clé) ; **phrase de passe** et double authentification ; un faux courriel « de la CAF » **signalé** à la directrice, puis affiche « Attention aux faux messages » pour les usagers.

8. Approfondissements (21.4)

Objets connectés : collecte excessive (GPS), mot de passe par défaut (« 0000 »), pas de mises à jour, hébergement inconnu, réutilisation commerciale, anxiété. Capteur de glycémie (une mesure toutes les 5 min) : **288/jour**, 8 640/mois, **105 120/an**. **Recommander une application** : éditeur, source des données (**Ciqual**), données demandées, hébergement et partage, suppression du compte, contenu sans promesse ni classement. **Une autorisation se justifie par une fonction utilisée** (photo et pas : oui ; GPS permanent, contacts, micro : non). Captures de glycémie : pas de messagerie grand public, mais la messagerie de Mon espace santé.

Travail à distance : matériel professionnel ; Wi-Fi public → **partage de connexion** ou **VPN** (connexion chiffrée vers le réseau de la structure) ; filtre de confidentialité ; pas de nom de patient à voix haute ; matériel jamais laissé dans la voiture. **Téléphone professionnel** : code d'au moins 6 chiffres, chiffrement, mises à jour, magasins officiels, pas de photo nominative, **effacement à distance**. Téléphone perdu (exemple 21.64) : référent, effacer, changer les mots de passe et l'**e-CPS**, bloquer la ligne, DPO, plainte. **Téléconsultation** : outil sécurisé, **lien unique par rendez-vous + salle d'attente**, pièce fermée et casque, pas d'enregistrement, identité vérifiée.

Diététicienne libérale, plan en trois temps : cette semaine (gratuit : double authentification, mises à jour automatiques, verrouillage, chiffrement) ; ce mois-ci (gestionnaire, 3-2-1, test) ; cette année (logiciel **HDS**, registre,

procédure d'incident, formation). Coût : 538,67 €/an = **0,60 €** par consultation (900/an) ; exercice 21.67 : 408 € = 0,34 € ; exercice 21.71 : 282 € = 0,24 € contre **2 150 €** pour une attaque.

Associations : référent, comptes nominatifs, outils en ligne avec double authentification, partage nominatif, mesures gratuites d'abord, liste papier ; **autodiagnostic en 10 questions** (« chaque non devient une action »).

Coter les risques : **niveau = vraisemblance × gravité** (1 à 4 chacune) : 1-3 faible, 4-7 modéré, 8-11 élevé, 12-16 critique. Exemple : 9 + 6 + 8 = 23 → 7 après mesures (**− 69,6 %**). Le chiffrement, la sauvegarde et la liste papier réduisent la **gravité** ; la formation et les mises à jour réduisent la **vraisemblance**.

Matériel en fin de vie : récupérer, déconnecter des comptes, **effacement sûr** ou destruction avec certificat, **attestation**. Le **photocopieur** multifonction garde une copie des documents sur son disque.

Assurance cyber : ce qui est couvert, les conditions exigées (sauvegardes, double authentification), l'assistance ; **plainte dans les 72 h**.

9. Pour aller plus loin, niveau L3 (21.5)

- **EBIOS Risk Manager** (ANSSI, **2018**) : **5 ateliers** : socle de sécurité, sources de risque, scénarios stratégiques, scénarios opérationnels, traitement du risque. Le diététicien apporte les **biens essentiels** (régimes, commandes, dossiers) et les conséquences de leur perte.
- **Culture juste** : **erreur** (soutien), **prise de risque** (accompagnement), **acte délibéré** (seul cas de sanction).
- **Économie des rançongiciels** : rançongiciel « en tant que service », affiliés, revendeurs d'accès ; attaques souvent **automatiques et opportunistes** : aucune structure n'est « trop petite ».
- Exercice 21.75 : hameçonnage 12 et rançongiciel 12 (liés), vol 6, erreur 6, incendie 4 (gravité maximale, couvert par la copie hors site). Exercice 21.76 : postes à jour 88,5 %, double authentification **77,5 %** (priorité), tests 75 %.

10. Les cas guidés (21.6)

Méthode de l'oral E5 pour le volet cybersécurité : **situer** (données, outils) → **évaluer** (ce qui peut arriver) → **protéger** (3-4 mesures) → **réagir** (qui prévenir) → **justifier** (règle datée).

Cas	Situation	Chiffres et réponse
1	Rançongiciel samedi 4 h, cuisine d'hôpital	303/820 = 37,0 % de repas adaptés ; 18 modifications depuis la liste de 14 h (5,9 %) ; 20 h × 31 € = 620 € ; CNIL vers mardi 5 h 30 ; export de nuit
2	Messagerie piratée (libérale)	Mot de passe réutilisé, pas de double authentification ; 640 contacts ; changer 2 mots de passe, vérifier les règles de transfert ; CNIL 72 h
3	Projet au collège (104 élèves)	Questionnaire anonyme, poste du centre, photos autorisées, aucune case de moins de 5
4	Tablettes des familles en EHPAD	31/86 = 36,0 % ; **réseau séparé**, outil choisi, pas d'application personnelle
5	Sensibilisation, SSIAD de 45 salariés	Clics 35,6 → 13,3 % (IC qui se chevauchent) ; signalements 6,7 → 37,8 % ; objectifs atteints
6	Panne de l'éditeur, cuisine scolaire	64 PAI sur 2 400 (2,7 %) ; 36 h × 29 € = 1 044 € ; RTO **zéro** pour les PAI : export quotidien + liste papier
7	Podomètres pour 40 adolescents	GPS : 288 × 91 × 40 = **1 048 320** positions inutiles ; pseudonyme, pas de classement, AIPD
8	Coter les risques d'un centre de santé	46 → 19 points = **− 58,7 %** ; A (messagerie) critique
9	Fausse facture de compléments	3 960 € / 96 = 41,25 € ; RIB différent, urgence ; rapprocher commande, livraison, facture

Cas	Situation	Chiffres et réponse
10	Déménagement d'un cabinet	Effacement sûr des PC, clés, imprimante (attestation), box réinitialisée
11	Tablette volée en visite	Chiffrée + effacement après 10 essais : 0,001 % ; sinon CNIL avant dimanche 15 h 50 et information des 27 patients
12	3 000 € pour une maison de santé	Coût du point : Wi-Fi 90 €, sauvegarde 120 € ; deux combinaisons à 27 points ; choix argumenté
13	Bilan envoyé à une homonyme	72 h depuis l'appel (mardi 16 h 05 → vendredi 16 h 05) ; 3,2 erreurs/an attendues ; INS, MSSanté
14	Poste partagé en cuisine	Compte « cuisine » → **badge** personnel, verrouillage court, historique des températures (preuve en cas de TIAC)
15	Sécuriser son propre stage	Initiales + âge + chambre + pathologie ≠ anonyme ; pseudonymiser ; clé perdue → prévenir la tutrice
16	Nouvelle diététicienne sans compte	Jamais le compte de la personne partie ; compte provisoire nominatif
17	Téléconsultation avec lien permanent	Une voisine entre : violation, risque élevé → informer + CNIL ; lien unique + salle d'attente
18	Fuite chez l'éditeur de la cantine	212/2 350 = 9,0 % d'enfants allergiques exposés ; la **commune** notifie (lundi 14 h → jeudi 14 h)
19	Faux SMS au nom d'un cabinet	Pas de lien dans le message de prévention ; 33700 ; plainte ; CNIL seulement si fuite
20	Étiquettes scannées d'une cuisine	72 Mo/jour, 9,4 Go en 130 jours, une seule copie : traçabilité rompue → 3-2-1, écriture protégée

11. Synthèse et jury (21.7-21.8)

Méthode E5 en 5 temps : situer · nommer le risque (D, I, C) · citer la règle **datée** (RGPD 2016 articles 32-33, L. 1111-8, ANSSI 2017, CNIL 2022) · proposer une mesure **immédiate et durable** · reconnaître les **limites**.

Erreurs fréquentes : « on change les mots de passe tous les mois » (mieux : long, unique, double authentification) ; « sauvegarde sur un disque branché » ; « éteindre l'ordinateur infecté » ; « le prestataire a été piraté, ce n'est pas notre problème » ; « on notifie la CNIL pour toute violation » (seulement si risque ; registre toujours) ; « sanctionner celui qui a cliqué » ; « trop petite pour être attaquée » ; « il y avait des fautes, c'était facile » ; citer **NIS 2** sans vérifier.

Fiche réflexe : mon compte, ma session verrouillée · devant un message : je ne clique pas, je vérifie, je signale · devant un paiement : rappel au numéro connu, double validation · incident : je débranche sans éteindre, j'appelle, je note, je ne paie pas · si l'outil tombe : le classeur du mode dégradé.

Liens : projet (chapitres 7-9), atelier (10-13), communication (14-15), étude (18), veille (19), numérique en santé (20).

QCM : 1 a, c, d · 2 a, b, d · 3 a, b, c · 4 b, c · 5 a, b, c · 6 a, b, d · 7 a, b, d.